

How informative are cybersecurity risk disclosures?

Empirical analysis of breached firms

Matthew Adams* and Tyler Moore

School of Cyber Studies

College of Engineering and Computer Science

The University of Tulsa

800 South Tucker Drive, Tulsa, Oklahoma 74104 USA

mla5406@utulsa.edu, tyler-moore@utulsa.edu

May 2025

Abstract

Public companies face escalating requirements to disclose cybersecurity risks and damages in regulatory filings. In theory, such disclosures should equip investors with knowledge required to make informed decisions, while also encouraging firms to adopt more robust strategies for managing cybersecurity risks. In practice, discussions are often embedded in disparate locations of long documents full of legalese, which hinders systematic examination. This paper examines the regulatory filings of 45 firms that experienced ransomware incidents between 2018 and 2021. We describe a process whereby 6,282 cyber-related statements were extracted from 249 10-K filings between 2018–23, then categorized using an iterative process inspired by grounded theory. We then perform quantitative and qualitative analysis of the statements, examining how firms discuss cybersecurity before and after experiencing an incident.

Keywords— Cybersecurity metrics, security economics, cybersecurity regulation, 10-K disclosure

1 Introduction

Cybersecurity presents an important and growing risk for firms of all sizes. Cyber incidents have been shown to significantly affect firm financial stability, customer retention, and reputation (W. Li et al., 2023; Schlackl et al., 2022; Woods and Böhme, 2021). Incidents continue to escalate in intensity and cost (Romanosky, 2016; Schlackl et al., 2022).

Against that backdrop, it is no surprise that investors and regulators are interested in improving how firm-level cybersecurity risks are presented and evaluated. Over the past decade and a half, the U.S. Securities and Exchange Commission (SEC) has placed increasingly substantial obligations on publicly-traded firms to disclose material cybersecurity risks and incidents. The rationale behind such regulatory action is to inform

*Corresponding author. Working paper, pre-publication draft.

investors of substantial risks that could otherwise remain hidden from view. It is also hoped that by requiring firms to disclose cybersecurity risks, firms will be pressured by the market to better manage these risks.

The efforts began in 2011 when the SEC released guidance clarifying that existing rules to disclose material risks in annual 10-K filings also cover cybersecurity risks (U.S. Securities and Exchange Commission, 2011). The guidance was expanded in 2018 (U.S. Securities and Exchange Commission, 2018), further specifying when and how cyber incidents and risks should be disclosed (Gao et al., 2020; H. Li, No, and Boritz, 2020). This regulation has had a noticeable effect on the increasing number of firms discussing cybersecurity risks within ‘Item 1A’, a section dedicated to the discussion of risk factors faced by the company. Most recently, the SEC issued a rule that led to the creation of ‘Item 1C’ in the annual 10-K filings, a section where companies are required to mention their risk management and governance policies related to cybersecurity. Item 1C became mandatory for all public companies starting in December 2023 (U.S. Securities and Exchange Commission, 2023, July).

What has the effect been of these growing disclosure requirements? Research suggests that such regulatory pressure, without rigid requirements, has resulted in declining levels of valuable information (H. Li, No, and Wang, 2018; Nelson and Pritchard, 2016). On the other hand, we know from other empirical research that proactive security investment results in fewer incidents (Gandal et al., 2023; Kwon and Johnson, 2014). Firms that proactively report the strategies they employ to mitigate cybersecurity incidents are transparent about the damages suffered from an incident. They outline the steps they took in reaction to suffering a breach to minimize the compromise, providing useful information to investors and regulators. We will argue in this paper that the statements made in regulatory filings can be used to measure cybersecurity posture at a firm level. In particular, we can deduce from the reports the extent of preparedness, transparency, and informativeness regarding disclosing cybersecurity incidents and mitigation strategies.

This firm-level behavior increasingly aligns with evolving regulatory expectations. The SEC’s 2018 disclosure guidance, as well as changing guidance requirements and guidance from other regulators and stock exchanges, highlight the importance of transparent cybersecurity disclosure (Peng and C.-W. Li, 2022). Higher quality disclosure can mitigate information asymmetries, and, according to Campbell et al., 2014 benefits the firm in various ways, such as reduced cost of capital. Additionally, not following such requirements leads to potential legal liability due to failure to disclose material risks to shareholders (Campbell et al., 2014).

Public regulatory filings, such as 10-K filings, offer a source of information on the cybersecurity posture of companies (Berkman et al., 2018; Celeny and Maréchal, 2023, October; Cheong et al., 2021; Gao et al., 2020; Hajizada and Moore, 2023; H. Li, No, and Wang, 2018; W. Li et al., 2023). However, boilerplate disclosure often plagues these reports, with generic recycled text bloating regulatory filings, diminishing transparency, and reducing informativeness (Gao et al., 2020; H. Li, No, and Wang, 2018; Nelson and Pritchard, 2016). Researchers disagree on boilerplate disclosure in 10-Ks; nonetheless, pursuing increased informativeness and transparency benefits investors and regulators.

We are not the first to utilize regulatory disclosures to measure cybersecurity. Other researchers have approximated cybersecurity effort through metrics such as the length of disclosure and frequency of cybersecurity-related phrases, using computational methods to quantitatively measure these filings (Berkman et al., 2018; Florackis et al., 2023; Wong et al., 2023). Alternatively, researchers have manually coded parts of the text to analyze the qualitative aspects of these disclosures, finding topics based on their findings (Wong et al., 2023).

In contrast, for this paper, we combine the two approaches using domain-specific attributes of cybersecurity. We conduct qualitative analysis of cyber-related statements to categorize what is being discussed, then apply the framework quantitatively to 6,282 cybersecurity-related statements made by 45 firms. Distinct from prior research, we have also focused on all U.S.-based publicly-traded companies that have been independently reported to have experienced a ransomware attack between 2018 and 2021. This enables us

to study how disclosures, and ultimately cybersecurity risk management, changes following a breach.

2 Categorizing cybersecurity disclosure text

2.1 Data collection methodology

The sample focuses on publicly traded companies that suffered ransomware incidents between 2018 and 2021. These companies were identified as having been breached by the Critical Infrastructure Ransomware Attacks (CIRA) dataset maintained at Temple University Aunshul Rege, 2025, where a manual search of the SEC EDGAR database was used to connect companies’ names to their respective Central Index Key (CIK) codes. The CIRA dataset recorded 946 ransomware incidents between 2018 and 2021. We inspected 566 of these companies. After removing duplicates and private companies, the sample size was reduced to 87 distinct public companies. Of the 87 companies, 45 companies had 10-Ks available for years between 2018 and 2023. Most of the other 42 companies were non-U.S. companies that had registered for CIK codes but did not have to file 10-K reports. Of these 45 companies, only one does not have a year of breach within CIRA. Additionally, nine other companies have fewer than six available 10-Ks for the time period for the following reasons: four of the companies became privately traded, three of the companies became publicly traded, and the final two companies merged, all within this six-year period.

The available 10-Ks were downloaded and subsequently parsed through a Python script, which extracted paragraphs related to cybersecurity based on the following keywords: ‘cyber’, ‘ransomware’, ‘breach’, ‘malware’, ‘phishing’, and ‘unauthorized’. These keywords were selected based on a manual review of the cybersecurity risk section from approximately half of the 10-K filings, capturing the most prominent cybersecurity-related terms.

2.2 Grounded theory process

Grounded theory is an iterative research approach in which data is collected and analyzed to develop theories and hypotheses inductively. This research took inspiration from grounded theory, ensuring a valid interpretation of the text statements and limiting the amount of bias within the categorization. The iterative process began with taking a random, unique, representative sample of the statements, resulting in a sample of 665 statements. These statements were then analyzed by three researchers, including the writers, where three rounds of iterative coding and discussions were completed. During the coding session, each coder would independently analyze a portion of the statements and assign one of the categories to them. During the discussion phase, problematic statements were identified and discussed. Discussion led to either a realization of the coder’s mistake during categorization or the adaptation of the definitions to more accurately capture the statements. After the third round the following four categories were realized: ‘Incident Response (IR)’, ‘Cybersecurity Damages (CD)’, ‘Prospective Cybersecurity Risks (PCR)’, and ‘Risk Mitigation Strategy (RM)’. Additionally, subcategories were created for each of the categories, with definitions developed and agreed upon by the two coders.

2.3 Category descriptions

Prospective Cybersecurity Risks (PCR) is defined as “statements that are forward-looking statements describing how and what could go wrong with cybersecurity”. Theoretically, this category aligns with the ‘Threat’ latent factor within the causal model espoused by Woods and Böhme, 2021. (Figure 1 shows the mapping of each category onto the model.) An example of a PCR statement is: “Despite our security measures, our information technology infrastructure may be vulnerable to attacks by hackers or breached due to

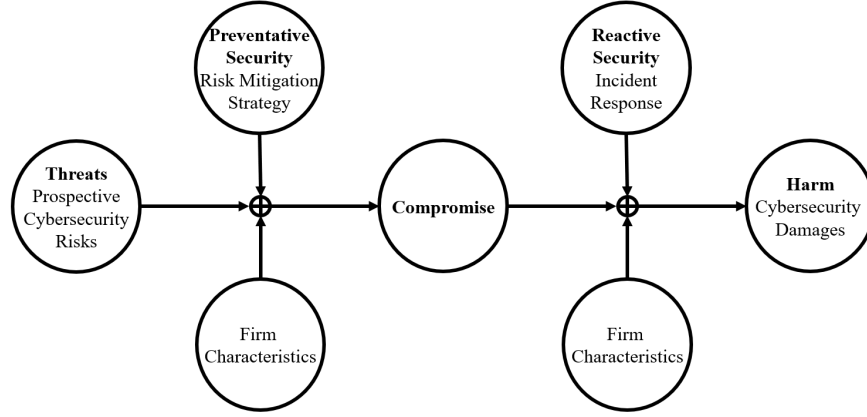


Figure 1: Causal model (Woods and Böhme, 2021) mapped to identified categories.

employee error, malfeasance or other disruptions.” This statement captures the company’s expectations of threat and uncertainty.

Risk Mitigation Strategy (RM) is defined as “statements that explain company strategies to mitigate the impact of a future cybersecurity incident.” Theoretically, this category aligns with the ‘Preventative Security’ latent factor within the causal model. An example of an RM statement is: “We proactively evaluate the cybersecurity risk of third-party IT providers and solutions by utilizing a repository of risk assessments and an external monitoring solution that includes threat intelligence to better inform us during contracting and vendor selection processes.” This statement captures the proactive strategies used by the company to reduce the potential for compromise.

Incident Response (IR) is defined as “statements that explain the steps companies took to limit the impact caused by an experienced incident directly” and was initially referred to as ‘Corrective Plan of Action.’ An example of an IR statement is: “Upon learning of the AMCA Incident, the company promptly stopped sending new collection requests to AMCA and stopped AMCA from continuing to work on any pending collection request from the Company.” This statement captures the company’s response once it discovers the incident to reduce the compromise’s further impact.

Cybersecurity Damages (CD) is defined as “statements that describe damages caused by cybersecurity incidents and any other results of such damage,” an important clarification is that, as they are results of a breach, statements referring to companies who are reimbursed by their cybersecurity insurance, as well as other positive outcomes, are also included, as they are consequences of the incident. An example of CD statements is: “We have incurred legal, settlement and other costs in connection with cyber incidents that have impacted us.” This statement captures the consequences suffered by the company that resulted from the cybersecurity incident.

In addition, this dataset tracks the following: ‘Ransomware’ - a boolean variable describing if the statement mentions the term ransomware within it and ‘Immaterial’ - a boolean variable describing if the statement refers to the harms sustained from cybersecurity incidents as immaterial, as well as subcategories within the primary categories.

Various subcategories emerged within each of the primary categories. They were analyzed and created using the same approach as the primary categories. Table 1 displays the various definitions.

Subcategory	Definition
Prospective Cybersecurity Risks (PCR) & Cybersecurity Damages (CD)	
Legal Costs	Statements that speak about legal consequences and proceedings stemming from a cyber-attack.
Business Disruption	Statements that speak about interruption of business operations stemming from a cyber-attack.
Reputation	Statements that speak about reputational damages stemming from a cyber-attack.
Third Party	Statements that mention that a cyber-attack is due to a related third-party incident or may affect related third parties.
Unauthorized User	Statements that speak about damages caused by users with falsified access (such as hackers).
Information	Statements that speak about the loss or compromise of confidential data due to a cyber-attack.
Financial Loss	Statements that speak about monetary losses stemming from a cyber-attack.
Risk Management (RM)	
Due Diligence	Statements that suggest the organization is employing all mechanisms to prevent cyber-attacks.
Program	Statements that mention the creation of or an existing system to resolve cyber-attacks.
Compliance	Statements that mention the resulting regulations that must be followed to resolve a cyber-attack.
Assessment	Statements that mention the company’s actions to get an overview of their cybersecurity defense system.
Committee	Statements that mention the creation of or an existing group to oversee cyber defense.
Third Party	Statements that mention the use of third-party services.
Training	Statements that mention a program designed to educate or spread awareness of cybersecurity.
Investment	Statements that mention increased resources being used to support cyber defenses.
NIST Framework	Statements that mention the use of the NIST framework.
Incident Response (IR)	
Reporting	Statements that mention notification to affected parties, stakeholders, and regulatory bodies.
Legal	Statements that mention interaction with the judiciary or law enforcement in relation to the incident.
System Shutdown	Statements that mention the company deliberately took their systems offline.
Experts	Statements that mention interaction or consultation with professionals in the related field.
Monitoring	Statements that mention that the company monitored the system’s security levels.

Table 1: Subcategory definitions.

3 Related work

3.1 Firm-Level Cybersecurity Measurements

Research has shown that cybersecurity incidents have lasting impacts on financial stability, customer retention, and brand reputation of firms (W. Li et al., 2023; Schlackl et al., 2022; Woods and Böhme, 2021). Despite such escalating claims about cyber-incident risks and inconsistent demonstrations of the efficiency of security interventions, cyber-risk management has been viewed as “more of an art than a science” (Woods and Böhme, 2021), signaling a need for systematic approaches to quantifying cyber risk. The causal model describes latent factors that highlight how cybersecurity threats become cybersecurity harms while simultaneously bringing in proactive and reactive security and firm-based factors to establish a holistic view of cybersecurity incidents (Woods and Böhme, 2021).

A challenging aspect of cybersecurity research is the lack of complete data (Woods and Böhme, 2021). Research that covers the entire life cycle of an incident has yet to be done, particularly analyzing the difference between proactive and retroactive cybersecurity investment. A firm’s cybersecurity posture is related to its transparency regarding its cybersecurity controls and when it implements such. Based on survey data from Israeli companies and their cybersecurity defenses, empirical research found that companies that

retroactively implemented risk mitigation systems had a significantly lower chance of suffering a cybersecurity breach (Gandal et al., 2023). Kwon and Johnson, 2014 finds that, within the healthcare sector, proactively investing in security controls reduces both the cost of security measures and the failure rate of such controls. The challenges in cybersecurity risk assessment are further highlighted by the reliance on publicly reported data, often resulting in biases such as the lack of significance of harms and the over-representation of large organizations in data breach studies (Cheong et al., 2021; Woods and Böhme, 2021).

Measuring firm-level cybersecurity posture is a prominent topic. Nagle et al., 2017 examines the number of open ports in firms' networks and identifies a correlation between such and cyber incidents stemming from botnets. Liu et al., 2015 similarly focused on firms' networks, gathering data on the number of misconfigurations and malicious activities that originate from said networks. The researchers used this data to construct a model that identifies whether a data breach will be reported. Sarabi et al., 2016 collected similar data, adding novelty in business sectors and breach types. This information helped identify which industries were more susceptible to specific risks. Most related to our research, Berkman et al., 2018 creates a measure of firm-level cyber awareness to examine its impacts on the firm's market value. This measure is based on the length and relevance of the disclosure within 10-K filings, using a self-developed dictionary based on the National Initiative for Cybersecurity Careers and Studies (NICCS) glossary to calculate relevance.

3.2 Regulation and Informativeness

The guidance made by the SEC in 2011 and 2018 heavily emphasized the need for specific and informative content (Gao et al., 2020; H. Li, No, and Wang, 2018), marking a pivotal shift in how companies disclose their risk (Cheong et al., 2021). Both Cheong et al., 2021 and H. Li, No, and Wang, 2018 note that this increased pressure caused a gap between regulatory intent and corporate response, as it led to firms disclosing more cybersecurity risk without them necessarily adequately capturing their actual level of risk (Peng and C.-W. Li, 2022). According to Cheong et al., 2021, these practices lead to diminished transparency, hindering investors' ability to make informed decisions. Additionally, firms display strategic behavior in their cybersecurity disclosures, particularly post-cyber incident (Cheong et al., 2021; Gao et al., 2020), with research finding a weakening correlation between the disclosure in Item 1A and subsequent cybersecurity incidents weakening following the 2011 guidance, indicating a decline in the informational value of these disclosure (H. Li, No, and Wang, 2018; Nelson and Pritchard, 2016).

Despite the SEC's attempts to guide firms towards transparent reporting through repeated guidance, 10-K filings are still characterized by boilerplate disclosure (Gao et al., 2020), which, due to it being both generic and recycled, is less meaningful to investors and regulators (Nelson and Pritchard, 2016). However, some researchers suggest that boilerplate disclosure is obsolete (Berkman et al., 2018; Campbell et al., 2014; H. Li, No, and Wang, 2018). Campbell et al., 2014 found that risk factor disclosure was incorporated into post-disclosure market measures, suggesting that said disclosure is informative for investors. While H. Li, No, and Wang, 2018 found that a higher length of cybersecurity disclosure is positively associated with increased cybersecurity incidents. Berkman et al., 2018 echoes such findings, providing evidence that following the 2011 SEC guidance, disclosure reflects cybersecurity awareness and thus is not just a boilerplate. However, Campbell et al., 2014 continues to state that "our results do not necessarily imply that critics who call for improvements to risk factor disclosure are wrong." For the benefit of investors and regulators, more informative and less generic disclosure of cybersecurity incidents should be pursued.

Firm-level cybersecurity disclosure practices are increasingly driven by evolving regulatory requirements and guidance. The SEC's 2018 guidance, along with similar requirements from stock exchanges and other regulatory bodies, reflect a growing belief that cybersecurity risks can be material and should be transparently disclosed (Peng and C.-W. Li, 2022). These developments highlight a broader recognition that cyber threats now rival other national security concerns (Campbell et al., 2014), and should be crucial

for shareholders' decision-making process. The cybersecurity disclosure should convey the material risks and uncertainties that could affect the performance of the companies (Campbell et al., 2014), and therefore should be readily available to potential and current shareholders. The omission of these risks and the opaque language that minimizes them could result in legal liability (Campbell et al., 2014; Nelson and Pritchard, 2016). Boilerplate disclosure undermines this required transparency and propagates information asymmetry. Disclosure that is updated annually and easily understood benefits investors and mitigates information asymmetries (Nelson and Pritchard, 2016). Enhances disclosure also improves investors' ability to assess risk, and, according to Campbell et al., 2014, it can lower a firm's cost of capital by reducing perceived uncertainty and risk correlation with the broader market, benefiting both investors and the firm itself. Based on these benefits, regulation of cybersecurity disclosure incentivizes transparent informative disclosure and enforces accountability.

3.3 10-K Cybersecurity Disclosure

Analysis of 10-K documents is plentiful, dating back almost two decades F. Li, 2008. The authors used EDGAR and 10-Ks to measure firms' risk sentiment based on the frequency of words related to risk and uncertainty within the filings. According to their findings, risk sentiment can be used to predict future returns with firms with a greater frequency change related to negative sentiment suffered from negative returns in the following year (F. Li, 2008), showing the potential usefulness of analyzing 10-K filings. This frequency-based methodology has become the standard for analyzing 10-Ks. Future research adopted a textual analysis approach, akin to a Bag-of-Words (BOW) methodology, focusing on metrics such as frequency of words, length of cybersecurity risk disclosure, and the presence of said risk disclosure (H. Li, No, and Wang, 2018). Likewise, other research has used computational linguistics to create a measurement that provides weight to words frequently found based on their predictive ability to ascertain future attacks (Jamilov et al., 2021).

The following papers are the ones most closely related to our objective. Florackis et al., 2023 develop a cybersecurity risk measure using textual analysis on Item 1A Risk Factors section. This analysis spans from 2007 to 2018 for the authors to capture a broad spectrum of cybersecurity risk disclosure and related cyber-attack incidents. These disclosures were compared to disclosures of firms that had experienced a significant cyber attack, using data from the Privacy Rights Clearinghouse to form a training sample. This measure used cosine and Jaccard similarity scores to estimate the degree of similarity between the training sample and the sampled firms (Florackis et al., 2023). Likewise, Peng and C.-W. Li, 2022 uses Vector Space Modeling (VSM) to calculate the change in disclosure modification before and after a cybersecurity incident based on similarly extracted text from 10-K filings, specifically looking at how firms alter their disclosures following a cybersecurity attack. This research looks at firms that suffered breaches between 2013 and 2016, finding that firms disclose more information once they have suffered an incident. However, they do not find any evidence of the quality of the disclosure changing post-incident (Peng and C.-W. Li, 2022). Finally, Wong et al., 2023 analyze how companies disclose confusing and ever-changing privacy legislation and resulting regulation legible to potential and current investors. This study focuses on nine large technology companies and examines disclosures between 2015 and 2020. Our paper follows a similar methodology to theirs, as they implement a thematic analysis process where two coders read 10-K documents and iteratively work through them, adding a qualitative layer to this process.

Our research intends to synthesize and expand upon these related works. Using a methodology inspired by grounded theory, we aim to integrate qualitative analysis with quantitative metrics. We analyze a sample of 45 companies, each having suffered a ransomware attack, to quantify how their disclosures change in relation to the incident, constructing a panel dataset. While this research does quantify statements, the goal is to move away from a frequency-based methodology, which can lose rich information and where observably boilerplate recycled statements may interfere with frequency-related measurements. Additionally, the

Year	2018		2019		2020		2021		2022		2023 1C		2023 1C	
	% Firms	Median # statements	% Firms	Median # statements	% Firms	Median # statements	% Firms	Median # statements	% Firms	Median # statements	% Firms	Median # statements	% Firms	Median # statements
Prospective Risk (PCR)	98	10	98	10	98	13	100	13	100	14.5	100	16	100	16
Incident Response (IR)	7	0	16	0	37	0	41	0	38	0	28	0	38	0
Risk Mitigation (RM)	60	1	61	1	65	1	73	2	80	1.5	79	2	97	22
Damages (CD)	40	0	48	0	72	2	93	4	88	3	87	3	95	3
TOTAL	98	11	98	12	98	18	100	21	100	21.5	100	24	100	47

Table 2: Primary Categories by Year

manual process of analyzing and categorizing all 6282 statements has allowed for the creation of qualitatively created categories and subcategories that, interestingly, echo the factors present in the causal model espoused by Woods and Böhme, 2021. Our research aims to quantify how these disclosures change – with future goals of comparing such to non-breached companies and database of software installation for further analysis.

4 Analysis

We now analyze the categorized statements in order to study variation by firm and in response to breaches. This analysis focuses on the overall proportion of firms that make cybersecurity statements delineated by category, as well as the median number of statements made in each category. In addition, this analysis will also capture how these disclosures change in relation to the breach. This analysis compares various subcategories and tags given to specific statements, based on specific words and phrases being used.

4.1 How have cybersecurity disclosures changed over time?

Table 2 reports how cybersecurity-related disclosures in annual reports have changed over time. We can see that overall, discussions involving cybersecurity have steadily increased. The median number of statements observed has steadily risen from 11 in 2018 to 24 in 2023 (excluding statements in the newly required Section 1C Cybersecurity, which was added in 2023). What firms discuss has also changed. While nearly all companies have discussed prospective risks since 2018, the other categories have steadily increased to varying degrees. For example, whereas in 2018–19, fewer than half of firms discussed damages, by 2021 the share rose to 93%, remaining high in subsequent years. The share of firms discussing risk mitigation strategies rose more modestly, from around 3 in 5 companies early on to more than 4 in 5 in later years.

Finally, we observe that most discussion focuses on prospective risks, with between 10–16 median statements. By contrast, most companies do not discuss incident response or risk mitigation strategies much.

As mentioned above, the SEC recently issued guidance to firms asking that they complete a new section entitled “1C Cybersecurity” for any disclosures submitted after the 18th of December 2023 (U.S. Securities

Year			-3	-2	-1	0	1	2	3	
# Firms			9	32	39	41	42	40	30	

	PCR	IR	RM	CD	Total
Ransomware	60%	16%	7%	62%	78%
Legal Costs	89%	11%	16%	49%	96%
Immaterial	2%	0%	0%	40%	42%

Table 4: Variables by Category

in each annual report. Such modest change suggests that firms disclosure of their risk mitigation strategies is not influenced by suffering a breach, and is likely more a reflection of increased regulatory and societal pressure to constantly be upgrading their layers of defense.

Incident response statements discuss incident response plans and the steps undertaken to contain the compromise and reduce damages. Such statements are even more rare than those outlining general risk mitigation strategies. As expected, most firms do not make such statements prior to an incident occurring (those that do are referring to prior incidents unrelated to the ransomware events we studied). More surprisingly, most breached firms do not discuss incident response in their filings even after the attack has taken place.

Damages come in many forms, such as business disruption, financial loss, and lawsuits. Compared to relatively extensive discussion of prospective cybersecurity risks, firms make fewer statements about damages. In the years following a ransomware attack, most but not all firms (88–95%) do explicitly discuss damages incurred. The median number of such statements is 4 for the year of the incident and next, slightly declining in later years. An important question is whether firms write consistently about the types of risks they face prior to breaches and the damages they discuss afterwards. We examine this in more detail next.

4.3 Do firms discuss risk consistently before and after incidents?

Given that all firms in our sample experienced a ransomware attack, a natural starting question is how many disclose this fact. Table 4 reports that 78% of firms mention ransomware at least once across all 10-K reports. It is somewhat surprising that the share is not higher, given SEC disclosure guidance.

Next, it is worth noting *where* ransomware is mentioned. Most often, ransomware is discussed as a prospective risk (60%) or in damages incurred (62%). Very few mention it within their incident response plans and even fewer regarding how they proactively plan to mitigate such risk.

In addition to disruption and the ransoms themselves, legal costs can be a major consequence of ransomware attacks. 96% of firms mention litigation, legal procedures and how cybersecurity risks are manifested in the law. Typically, these are discussed as a prospective risk. However, less than half of the firms mention resulting damages as a result of such litigation (usually in the form of punitive cases or regulated practices). Within both incident response and risk mitigation disclosure, firms discuss legislation and regulation far less. These results echo those of Wong et al., 2023 which find that new regulations and, importantly, data breach reporting requirements, are viewed as cybersecurity risks and are viewed similarly to what would define as prospective risks.

The SEC Cybersecurity guidance requires firms to discuss “material” cybersecurity risks. While almost no firm explicitly admits to a risk or event rising to the level of materiality, many do the opposite. 42% of firms make statements about the immateriality of cybersecurity risks, with fully 40% of firms qualifying discussions of damages by stating that they are immaterial.

We next consider *when* risks and damages are discussed. Do firms change how they talk about risk and damages after a breach occurs? Table 5 seeks to answer this question. The first two columns capture ransomware and legal costs, comparing how they change pre- and post-breach, as well as how often they are mentioned in damages. The goal of the bottom half of the table is to tease out the timing more clearly

so we can determine whether statements of prospective risks made in the years prior to a ransomware event accurately reflect the damages they later experience.

Before the breach only 18% of firms discuss ransomware as a prospective risk. Afterwards, 59% do, with 64% mentioning ransomware as a source of damages. The bottom half of the table makes the distinction more precise. Only 14% of the firms discuss the potential for ransomware and later report damages resulting from it. An additional 5% discuss the potential of ransomware beforehand but do not mention it in their damages.

By contrast, half of the firms did not discuss ransomware as a prospective risk prior to being attacked but did so when they discussed damages afterwards. Hence, these firms did not accurately identify cybersecurity risks in advance. A further 32% of firms fail to mention ransomware in either their prospective risks before the attack or in their damages. There are two possible explanations. Either these firms were not substantially affected by ransomware attacks or they have not sufficiently transparent in disclosing the risk or damages experienced.

We observe that there appears to be little relationship between disclosing a particular risk before the breach and whether or not damages are later reported. Overall, a slightly greater share of firms report risks before the breach and later report on damages (43% to 34%). But the share is similarly split for those that do not disclose risks in advance of a breach (12% vs 11%). Broadly speaking, the same story holds true for particular subcategories indicated in the table's columns. These subcategories were observed in both the statements on prospective risk and damages. While there is some variation, a chi-squared test indicates no statistically significant difference in proportion.

One takeaway from this analysis is that a minority of firms are not being sufficiently transparent in discussing cybersecurity threats. 11% of the time, there is no discussion about risks before or any reporting of damages. A much larger share discuss only one side of the issue, either the risk or the damages, but not both. Given that all of these companies confirmed to have experienced ransomware, this is troubling.

Some types of risks are discussed more than others. 89% discuss business disruption risk prior to a breach, compared to 59% discussing third-party risks before an incident. After the breach, all subcategories are discussed more frequently as a prospective risk. However, there can be great variation in terms of damages. The most common types of damage discussed are financial losses (75%) and business disruption (73%). This makes sense, given that 95% and 80% of firms, respectively, discuss these a prospective risks after the attack. By contrast, while 93% of firms discuss reputational damage as a risk post-breach, only 32% of firms acknowledge damage to their reputation in the filings. Similarly, while 91% of firms discuss information risks post-breach, just 50% acknowledge experiencing the same type of damages from the incident. This is surprising given that ransomware attacks quite commonly harm confidentiality and integrity of enterprise data.

We can also examine the data at the level of the firm. On average, firms discuss 5.4 of the 7 subcategories as a prospective risk prior to the breach, rising to 6.25 of the 7 subcategories after the breach. However, just because a firm identifies a risk, that does not guarantee they will admit to experiencing damages. On average, firms report damages for 3.9 subcategories. For 3.0 subcategories, damages and pre-breach risk align. For 2.4 subcategories, firms report damages but did not identify the subcategory as a risk prior to the breach. This can be interpreted as a blind spot in its annual reporting before the incident. After the breach, 3.6 subcategories on average are reported as having experienced damage and a prospective risk going forward. However, for 2.7 subcategories where damage was reported, the same type of prospective risk is not identified.

From the above discussion, we conclude that firms consistently fail to accurately identify some types of risk before a breach. Moreover, they do not always learn from experience by updating their prospective risks based on the damages they actually experience.

	Ransomware	Legal Costs	Business Disruption	Reputation	Third Party	Unauthorized User	Information	Financial Loss	Average
Pre-Breach Risk (PCR)	18%	73%	89%	84%	59%	73%	82%	80%	77%
Post-Breach Risk (PCR)	59%	84%	95%	93%	82%	91%	91%	89%	89%
Damages (CD)	64%	50%	73%	32%	50%	57%	50%	75%	55%
Pre-Breach Risk & Damages	14%	36%	68%	30%	30%	43%	39%	57%	43%
Pre-Breach Risk & No Damages	5%	36%	20%	55%	30%	30%	43%	23%	34%
No Pre-Breach Risk & Damages	50%	14%	5%	2%	20%	14%	11%	18%	12%
No Pre-Breach Risk & No Damages	32%	14%	7%	14%	20%	14%	7%	2%	11%

Table 5: Comparing pre-and post-breach risk to the reporting of damages by subcategory.

4.4 Does disclosing cyber risk management strategies in advance affect outcomes post-breach?

We know from Table 3 that firms make much fewer statements about their cyber risk management strategies compared to discussions of prospective risks. Around half of firms include a statement about their risk mitigation strategies before a ransomware incident, steadily rising to around 80% in the years following a breach. RM statements are useful because they often indicate good cybersecurity posture and proactive investment following an incident. Table 6 summarizes the number of firms that mention RM strategies pre and post-breach, and compares them to other variables of interest. The table also includes the amount of firms that disclose incident response (IR), a particular form of reactive risk mitigation, in relation to the same variables.

Immaterial captures the firms which specifically mention that the damages suffered were “not material” in their effects. As seen in the table, 18 of 44 firms (41%) report that the breach suffered was immaterial. Of those 18, 10 of them mention RM pre-breach. One might anticipate that firms who undertake better risk mitigation ahead of a breach are less likely to suffer a material loss. In fact, we observe no statistically significant difference.

Interestingly, 17 of those 18 firms report on RM post-breach. This suggests that firms that state damages were not material, include RM statements post-breach to justify why there breach was immaterial. This is logical when considering that companies want to inform investors and regulators about how they successfully overcome the breach and how they plan to continue improving on their risk mitigation strategies.

Interestingly, none of the firms mention that a breach has had a material impact on the firm, though some firms do discuss the monetary damages caused by said breaches, Damages captures such. If a firm discloses a monetary amount of damages caused by the breach, this variable captures them. Likewise, if a firm does not mention any monetary amount of damages suffered, they are captured in No Damages. As seen in the table, 12 firms state specific monetary damages relating to a breach, while 32 do not mention any monetary damages. When comparing the two, 21 of the 32 companies who report no damages also disclosed RM pre-breach, while 4 of the 12 companies who suffered damages reported on RM pre-breach. This suggests that companies who report on RM before a breach are less likely to mention monetary damages suffered. This leads to the thought that companies that proactively disclose risk mitigation strategies also tend to suffer

Category	Total		Pre-Breach RM		No Pre-Breach RM		Post-Breach RM		No Post-Breach RM		Incident Response		No Incident Response	
	#	%	#	%	#	%	#	%	#	%	#	%	#	%
Immaterial	18	41	10	56	8	44	17	94	1	6	10	56	8	44
No Immaterial	26	59	15	58	11	42	17	65	9	35	12	46	14	53
\$ Damages	12	27	4	33	8	67	11	92	1	8	11	92	1	8
No \$ Damages	32	73	21	66	11	34	23	72	9	28	11	34	21	66
Legal Costs	22	50	11	50	11	50	20	91	2	9	14	64	8	36
No Legal Costs	22	50	14	64	8	36	14	64	8	36	8	64	14	36

Table 6: Comparing Risk Mitigation Disclosure

less monetary damages than those who do not disclose their risk mitigation strategies beforehand. Of the same 12 firms that disclose damages, 11 of them disclose RM post-breach, a 140% increase. When looking at the same firms, 11 of them disclose their incident response plan. Both of these suggest that the firms that disclose damages, resultingly alter their disclosure patterns in a manner that reflects the severity of said damages, increasing both RM and IR provides useful information to investors.

Finally, Legal relates to the aforementioned Legal subcategory, where firms that mention damages suffered in terms of legal procedures, are captured. Likewise, if a firm does not mention any legal damages, they are captured in No Legal. As seen in the table, exactly half the firms report on legal procedures arising from incidents. Specifically, when looking at RM disclosure post-breach, 20 of the 22 firms that disclosed legal procedures disclosed RM post-breach a noticeable increase from the perfect split of firms that disclosed RM pre-breach. Interestingly, when looking at the firms that did not disclose legal damages, the amount that disclose RM pre and post breach are identical. These results suggest that legal damages alter the way in which firms disclose. This is evident due to the change between periods for those affected and the lack of change seen in those unaffected.

Touching on IR as a whole, for the least disclosed category, it is notable that companies that mentioned either immateriality, damages, and legal procedures, all had the higher proportion of firms that disclose IR. When compared to previous results that showed that less than half of the firms discuss IR at all, it suggests that these firms are more transparent with their disclosure, due to both the presence of valuable variables as well as the inclusion of IR. An alternative explanation, when only addressing damages and legal - the variables that link directly to suffered impact, that firms that disclose such feel it necessary to disclose on their incident response plan in order to assure investors and regulators that they are managing the incident in a comprehensive manner. When paired with the previous discussion on changing RM levels, this explanation becomes more credible, supporting the value in these variables.

Table 7, compares the companies that included monetary amount of damages based on if they also said such damages were immaterial. Noticeably, companies that mention Immateriality suffer lower median damages but higher mean damages showing a discrepancy. While taking the previous discussion on damages into account, this may suggest that, though the monetary damages are higher, the resulting RM disclosure

	# Firms	Median Amount	Mean Amount	# Firms
Immaterial	6	\$16300000.00	\$80136073.33	12
No Immaterial	6	\$19950000.00	\$33854666.67	21

Table 7: Immaterial vs Damages

and its implementation may reduce the severity of the damages suffered regardless of the actual amount. This echoes previous theory that proactive investments result in both reduced breaches and a reduced failure rate of controls (Gandal et al., 2023; Kwon and Johnson, 2014).

5 Case studies

This section will analyze 5 different corporations, based on the informativeness and the quantitative summaries of their statements. In order to ensure that they are all comparable within their 10-K disclosures, only companies that were breached in either 2020 or 2021 and have all six 10-K’s available, as well as having a year of breach in the CIRA dataset, were eligible for this analysis. These limitations are required to keep the amount of disclosure before and after the breach consistent to allow for an apt comparison.

5.1 Informative Disclosure

We have identified CIK 0000021175 CNA FINANCIAL CORPORATION as having one of the most informative disclosure practices. CNA reported that it was breached in March 2021, as seen in the following: “We sustained a sophisticated cybersecurity attack in March 2021 involving ransomware that caused a network disruption and impacted certain of our systems.” This statement captures transparency by providing both the cause of the attack and ransomware, a word that only 64% of firms mention within their disclosure when referring to the damages and when the attack took place - a variable many companies do not mention. CNA also clearly explains what damages they have sustained:

Our investigation into the incident revealed that an unauthorized third party copied some personal information relating to certain current and former employees, contract workers and their dependents and certain other persons, including some policyholders.

On the other hand, they notably fail to mention any specific monetary amounts or how much personal information (or which information) was exposed.

CNA also shows transparency within their incident response plans:

Upon detection, we undertook steps to address the incident, including engaging a team of third-party forensic experts and notifying law enforcement and key regulators. We restored network systems and resumed normal operations.

This is also in: “In July 2021, we provided notifications to the impacted individuals and regulators, by applicable law.” These statements show they are more open than most firms with incident response plans. CNA also refers to their cybersecurity coverage:

Although we maintain cybersecurity insurance coverage insuring against costs resulting from cyber-attacks (including the March 2021 attack), we do not expect the amount available under our coverage policy to cover all losses.

Although this suggests that it was not enough to cover their losses, the fact that they had proactively taken such insurance suggests greater awareness of the present threats. They also disclose their strategies to promote their defenses and how much investment is due to the recent attacks: “Some of these investments are a direct result of the March 2021 cybersecurity attack, described in the immediately following risk factor, which is not recoverable under existing insurance coverage.” However, the statement on investments is not that informative: “We have invested and continue to invest in the security of our systems and our technology infrastructure on an enterprise-wide basis.” and “We have made, and continue to make, investments to improve our security and infrastructure.” While these statements are not very descriptive, the fact that they refer to the breach as the meaning of such investments shows that CNA has internalized the threat to their business.

CNA’s disclosure also captures the story of the event. After the initial compromise, due to a third party, CNA started making reactive risk statements regarding the breach in 2021 - the year of the breach: “The risk of a breach can exist whether software services are in our data centers or are cloud-based software services.” This increased text disclosure follows previous research suggesting that firms react to a compromise (H. Li, No, and Wang, 2018). CNA also follows up on the dangers related to their vendor’s systems and how such may affect them in 2023:

The risks relating to future breaches in our, or our vendors’, data security infrastructure, including in connection with cyber incidents, could have a material adverse effect on our business, results of operations or financial condition or may result in operational impairments and financial losses, as well as significant harm to our reputation.

This statement is additionally valuable as it only occurred from 2023 onwards, showing growth within their disclosure. However, this statement is repeated twice in the 2023 disclosure. Finally, CNA was one of the companies already implementing Item 1C within this disclosure, showing attention to the upcoming regulatory requirements.

It is usual for companies to repeat statements year after year, referred to as boilerplate disclosure. However, CNA has a few examples of repeating the same statements multiple times within the same 10-K. This repetition can be seen as unnecessary bloat, undermines the previously mentioned increase of text disclosure, and supports our notion to move away from purely frequency-based quantitative methods. CNA also mentions that such a breach was immaterial:

Based on the information currently known, we do not believe that the March 2021 cybersecurity attack will have a material impact on our business, results of operations or financial condition, but no assurances can be given as we continue to assess the full impact from the incident, including costs, expenses and insurance coverage.

This statement is interesting, as while they do not expect it to be immaterial, they do expect it not to be fully covered by their cybersecurity insurance, suggesting a disconnect between cyberinsurance and damages - which is a trend within the statements captured or a disconnect between prospective damages and immateriality, however, this could be explained by the cyberinsurance limiting the materiality of the damage.

While CNA’s disclosure is not perfect, none are. CNA displays transparency regarding the fact that they have suffered a ransomware incident and when they suffered such. CNA explained why this occurred and reflected it in their following disclosures. All of this will aid investors and regulators when analyzing their 10-Ks and promote helpful information. Unfortunately, not all companies disclose incidents similarly.

5.2 Pitfall Disclosures

The following three disclosures each highlight common disclosure pitfalls, shedding light on how disclosure patterns can be improved. We begin by analyzing CIK 0000912752 SINCLAIR BROADCAST GROUP

INC, which highlights disconnectedness between fore casted risks and realized damages. Sinclair has some noticeably good disclosure statements, giving both the date of the incident and a monetary amount of damages suffered as reported in 2021:

The cybersecurity incident identified on October 17, 2021, resulted in the loss in the fourth quarter of 2021 of approximately \$63 million in advertising revenue, primarily related to our broadcast segment, as well as approximately \$11 million through the date of filing this Form 10-K in costs and expenses related to mitigation efforts, our ongoing investigation, and the security improvements resulting therefrom.

These two elements are both informative and show a care about transparency. Additionally, they also continue to discuss the damages informatively:

The cybersecurity incident identified on October 17, 2021, resulted in the loss in the fourth quarter of 2021 of approximately \$63 million of advertising revenue, primarily related to our broadcast segment, as well as approximately \$7 million through the date of filing of this Form 10-K in costs and expenses related to mitigation efforts, our investigation, and the security improvements resulting therefrom.

This statement was disclosed in 2022, showing that they continue to adapt their disclosure to use up-to-date numbers. Additionally, Sinclair mentions the presence of a ransomware attack and how the company aims to combat such:

Since the ransomware incident, our Board of Directors formed a cybersecurity subcommittee to provide greater oversight of the Company's cybersecurity measures and preparedness.

This is an excellent example of adjusting the disclosure to reflect the incident. However, Sinclair fails to maintain a qualitative connection.

Sinclair reported prospective risks prior to the breach related to subcategories: Business Disruption, Reputation, Third Party, Information, and Financial Loss; it had damaged in: Legal, Business Disruption, Information and Financial Loss. Additionally, their prospective risks post-breach increase for: Legal, Business Disruption, Third Party, Unauthorized User, and Financial Loss, with Information even decreasing. Quantitatively, this mismatch between prospective risks and materialized damages shows a disconnect in awareness of a breach as, for example, any investors who had read their disclosure pre-breach have any information to assume that Legal issues may arise from a cybersecurity breach. Another example of the disconnect is Third Party, where prospective risks were present before the breach and increased post-breach, but no damages were associated. The increase in the risks section suggests that it is not based on realized risk but on regulatory pressures or the need to bloat their filings instead of providing relevant information related to risks and damages.

Our next disclosure case is CIK 0001050825 STEELCASE INC. Steelcase's filings exemplify companies whose disclosures indicate a lack of awareness of any cybersecurity threat. Steelcase was the only company not to disclose any statements relevant to cybersecurity within their entire 10-K in the years before the breach. This changed post-breach when they added vague statements such as: "We may be adversely affected by security breaches, errors or disruptions relating to our software and software-as-a-service offerings." There is also a discrepancy within their disclosure. According to the CIRA dataset, they suffered a ransomware breach in 2020; however, according to their disclosure, they first detected the cyber attack in 2021: "In Q3 2021, we detected a cyber-attack that resulted in unauthorized access to our information technology systems." Post-incident Steelcase reported primarily on the prospective risks of cybersecurity and slightly on the materialized damages of said breach. Intriguingly, Steelcase reports on the monetary damages of the incident as follows:

To protect our systems during that cyber-attack, we temporarily shut down our global operations, which resulted in a delay of approximately \$60 [Million] in revenue from Q3 2021 to Q4 2021; however, we do not believe this incident had or will have a materially adverse impact on our business, operating results or financial condition or the effectiveness of our internal controls.

This statement has valuable information, such as their belief that such a breach would be immaterial. Steelcase's filings reveal a company that learned from its mistake; that mistake is not believing that cybersecurity risks were worth disclosing before the breach. As previously mentioned, any informative content should be pursued to benefit regulators and stakeholders.

The final disclosures belongs to CIK 0000028823 DIEBOLD NIXDORF, INC. Diebold fails to address the damages in their disclosure, with the closest linking statement to damages being:

We have experienced cybersecurity incidents in the past, but none of these incidents, individually or in the aggregate, has had a material adverse effect on our business, reputation, operations or products.

While the statement does not mention any damages, it alludes to the fact that they have suffered them in the past and were immaterial. This aligns with the central issue of Diebold, where, post-breach, they vastly increased their disclosure on prospective risks. However, any damages suffered are not present in the disclosure. This suggests that their primary way of informing investors and regulators is in the form of prospective risks, hypothetical issues that could arise, such as this statement introduced post-breach:

Although we have implemented cybersecurity measures designed to detect and limit the risk of unauthorized access to our systems and acquisition of, loss, modification of, use, access to, or disclosure of our data, threat actors are using evolving, sophisticated, and ever-changing techniques to obtain unauthorized access to systems and data.

Statements like this suggest that regardless of what the company does, breaches are still inevitable, a pattern found within all disclosures. These statements are less informative than statements that address actionable plans or materialized damages as they do not offer transparent information. For completeness, Diebold had also implemented Item 1C in 2023, showing an awareness of changing regulations.

5.3 Lackluster Disclosure

When looking for an example of a lackluster disclosure, our mentality focused on a company whose disclosure an investor would read before and after a compromise and would struggle to see any relevant change in information presented. Both the quantity of prospective risks and risk mitigation do not substantially increase post-breach, and there is a lack of materialized cybersecurity damages or any statements describing their incident response plan. The best example is CIK 0000912463 GUESS INC. Guess Inc. does not reflect much change within its disclosures. They fail to mention any statements that relate to their incident response plan. However, noteworthy, this brings them in line with 51% of all the companies who also fail to do so. Their statements disclosing risk mitigation strategies do remain constant, with the following statement appearing in 2018, 2019, and 2020:

We believe that high levels of automation and technology are essential to maintain our competitive position and support our strategic objectives and we continue to invest in and update computer hardware, network infrastructure, system applications and cyber security.

It changed a small amount in 2021, “We continue to invest in and update computer hardware, network infrastructure, system applications and cyber security.” In 2022, it changed to: “We continue to invest in new technologies and update computer hardware, network infrastructure, system applications and cyber security.” In 2023, it changed to: “We continue to invest in new technologies and update computer hardware, network infrastructure, system applications, and cyber-security.” All these changes are minor, and while they are not intentional, this may interfere with research focusing on unique statements and textual changes in 10-Ks.

Additionally, when Guess does speak about damages, their statements are vague and give little to no information on what happened - though they do manage to state that such damages were immaterial: “While we do experience damage or interruption to our systems, such events have not in the past had a material adverse impact on our business, financial condition, or results of operations.” Guess Inc.’s disclosure changes the least when comparing their quantitative and qualitative statements before and after the breach. While that does not necessarily mean they have a poor cybersecurity posture, it suggests such to any investors and regulators interested in their disclosure. While they were our highlighted disclosures, many other disclosures make these mistakes. As already mentioned, 51% of companies fail to report on any form of incident response, while almost all companies (with Steelcase Inc. being the only exception pre-breach) report on their prospective risks. Not all statements disclosed are equally valuable to investors and regulators.

6 Discussion

6.1 Limitations

There are a few limitations to this research at its current point. While initially more of a potential issue, lessened by our iterative collaborative approach, there may still be inconsistencies in the raw text examples extracted from the 10-Ks and the potential of bias in the coding done. The broad nature of 10-K disclosure inherently results in this, making it tricky to gauge specific statements. We have removed mainly this bias through the natural validation process we apply during our process, which was the specific reason for having it inspired by grounded theory.

Another limitation of this project is the current view that each statement can only relate to one of the four primary categories. Previous cybersecurity incidents have become a secondary category, as is evident by Previous Cybersecurity Incident. However, depending on the interpretation, many statements can easily be divided into two primary categories, three or four. This issue has been lessened due to altering the original category definitions, making each category more unique. However, specific statements are easily still applicable to more than one category.

6.2 Future work

We analyzed the presence of subcategories in both the PCR and CD statements. In future, we will expand the analysis to include subcategories for other categories. Deeper analysis required a sophisticated analysis method. Imploring methods such as Natural Language Processing (NLP), VSM, or utilizing a large language model (LLM) could improve this analysis. This improvement could come in various spaces, such as improving the ability to find subcategories that we may have missed or incorrectly grouped. Additionally, it could enhance the manual categorization of future 10-K disclosures.

Our next objective is to use a matched pair dataset. We will find a sample of 45 companies, using the same methodology, looking for companies that have not suffered a ransomware breach between the years 2018 and 2021. These companies will be analyzed identically, comparing primary category counts and overall statement quality. The results of this research would allow for a holistic understanding of how

firms respond to breaches within their disclosure and will allow us to identify patterns linking the companies. These patterns, or lack thereof, will contribute to the ongoing discussion of boilerplate disclosure, emphasizing noticeable trends between companies hit by a ransomware attack and those that were not.

7 Conclusion

Transparent and informative cybersecurity disclosure benefits investors and regulators. We have examined up to six years of 10-K annual filings for 45 publicly-traded firms that experienced ransomware incidents. We manually labeled 6,282 cybersecurity-related statements extracted from the filings using a categorization developed through an iterative process inspired by grounded theory. Using the categorized data, we presented a method to analyze how firms' disclosure changes following a ransomware incident.

Our results indicate disclosure trends toward prospective risks, an increasing proportion of firms disclosing mitigation strategies, and less than half indicating incident response strategies – suggesting a lack of transparent information. Likewise, our research shows that firms struggle to connect types of prospective risks with materialized damages, let alone fail to realize the risks of ransomware – suggesting a lack of awareness of ongoing threats. These results have demonstrated the significant promise of analyzing such data deeper in future. Even now, the manually crafted dataset can help investors, regulators, and academics guide future analysis of cybersecurity risk in 10-K disclosures.

8 Acknowledgments

We gratefully acknowledge support from the US National Science Foundation Award No. 2147505.

References

- Aunshul Rege. (2025). *Critical infrastructure ransomware attacks (CIRA) dataset* (tech. rep. No. Version 12.13) (<https://sites.temple.edu/care/cira/>). Temple University.
- Berkman, H., Jona, J., Lee, G., & Soderstrom, N. (2018). Cybersecurity awareness and market valuations. *Journal of Accounting and Public Policy*, 37, 508–526. <https://doi.org/10.1016/j.jaccpubpol.2018.10.003>
- Brown, S. V., & Tucker, J. W. (2011). Large-sample evidence on firms' year-over-year MD&A modifications. *Journal of Accounting Research*, 49, 309–346. <https://doi.org/10.1111/j.1475-679X.2010.00396.x>
- Campbell, J. L., Chen, H., Dhaliwal, D. S., min Lu, H., & Steele, L. B. (2014). The information content of mandatory risk factor disclosures in corporate filings. *Review of Accounting Studies*, 19, 396–455. <https://doi.org/10.1007/s11142-013-9258-3>
- Celeny, D., & Maréchal, L. (2023, October). Cyber risk and the cross-section of stock returns. <https://doi.org/http://dx.doi.org/10.2139/ssrn.4587993>
- Cheong, A., Yoon, K., Cho, S., & No, W. G. (2021). Classifying the contents of cybersecurity risk disclosure through textual analysis and factor analysis. *Journal of Information Systems*, 35, 179–194. <https://doi.org/10.2308/ISYS-2020-031>
- Florackis, C., Weber, M., Michaely, R., & Louca, C. (2023). Cybersecurity risk. *The Review of Financial Studies*, 36, 351–407. <https://doi.org/https://doi.org/10.1093/rfs/hhac024>

- Gandal, N., Moore, T., Riordan, M., & Barnir, N. (2023). Empirically evaluating the effect of security precautions on cyber incidents. *Computers and Security*, 133. <https://doi.org/10.1016/j.cose.2023.103380>
- Gao, L., Calderon, T. G., & Tang, F. (2020). Public companies' cybersecurity risk disclosures. *International Journal of Accounting Information Systems*, 38, 100468. <https://doi.org/10.1016/j.accinf.2020.100468>
- Hajizada, A., & Moore, T. (2023). On gaps in enterprise cyber attack reporting. *Proceedings - 8th IEEE European Symposium on Security and Privacy Workshops, Euro S and PW 2023*, 227–231. <https://doi.org/10.1109/EuroSPW59978.2023.00030>
- Jamilov, R., Rey, H., & Tahoun, A. (2021). The anatomy of cyber risk. <http://www.nber.org/papers/w28906>
- Kwon, J., & Johnson, M. E. (2014). Proactive versus reactive security investments in the healthcare sector. *Paper Knowledge . Toward a Media History of Documents*, 38, 451–472.
- Li, F. (2008). Do stock market investors understand the risk sentiment of corporate annual reports? <https://doi.org/10.2139/ssrn.898181>
- Li, H., No, W. G., & Boritz, J. E. (2020). Are external auditors concerned about cyber incidents? evidence from audit fees. *Auditing*, 39, 151–171. <https://doi.org/10.2308/ajpt-52593>
- Li, H., No, W. G., & Wang, T. (2018). SEC's cybersecurity disclosure guidance and disclosed cybersecurity risk factors. *International Journal of Accounting Information Systems*, 30, 40–55. <https://doi.org/10.1016/j.accinf.2018.06.003>
- Li, W., Leung, A., & Yue, W. (2023). Where is it in information security? The interrelationship among it investment, security awareness, and data breaches. *MIS Quarterly*, 47, 317–342. <https://doi.org/10.25300/misq/2022/15713>
- Liu, T., Sun, Y., Liu, Y., Gui, Y., Zhao, Y., Wang, D., & Shen, C. (2015). Abnormal traffic-indexed state estimation : A cyber – physical fusion approach for smart grid attack detection. *Future Generation Computer Systems*, 49, 94–103. <https://doi.org/10.1016/j.future.2014.10.002>
- Nagle, F., Ransbotham, S., & Westerman, G. (2017). The effects of security management on security events. *Workshop on the Economics of Information Security (WEIS)*, 1–18.
- Nelson, K. K., & Pritchard, A. C. (2016). Carrot or stick? The shift from voluntary to mandatory disclosure of risk factors. *Journal of Empirical Legal Studies*, 13, 266–297. <https://doi.org/10.1111/jels.12115>
- Peng, J., & Li, C.-W. (2022). Security breaches and modifications on cybersecurity disclosures. *Journal of Accounting and Management Information Systems*, 21. <https://doi.org/10.24818/jamis.2022.03007>
- Romanosky, S. (2016). Examining the costs and causes of cyber incidents. *Journal of Cybersecurity*, 2, 121–135. <https://doi.org/10.1093/cybsec/tyw001>
- Sarabi, A., Naghizadeh, P., Liu, Y., & Liu, M. (2016). Risky business : Fine-grained data breach prediction using business profiles. *Journal of Cybersecurity*, 2, 15–28. <https://doi.org/10.1093/cybsec/tyw004>
- Schlackl, F., Link, N., & Hoehle, H. (2022). Antecedents and consequences of data breaches: A systematic review. *Information and Management*, 59, 103638. <https://doi.org/10.1016/j.im.2022.103638>
- U.S. Securities and Exchange Commission. (2011). Cf disclosure guidance: Topic no. 2 [<https://www.sec.gov/rules/other/2018/34-83723.pdf>].

- U.S. Securities and Exchange Commission. (2018). Commission statement and guidance on public company cybersecurity disclosures [<https://www.sec.gov/rules/interp/2018/33-10459.pdf>].
- U.S. Securities and Exchange Commission. (2023, July). Cybersecurity risk management, strategy, governance, and incident disclosure final rule [<https://www.sec.gov/files/rules/final/2023/33-11216.pdf>].
- Wong, R. Y., Chong, A., & Aspegren, R. C. (2023). Privacy legislation as business risks: How GDPR and CCPA are represented in technology companies' investment risk disclosures. *Proceedings of the ACM on Human-Computer Interaction*, 7. <https://doi.org/10.1145/3579515>
- Woods, D. W., & Böhme, R. (2021). Systematization of knowledge: Quantifying cyber risk. *IEEE Symposium on Security and Privacy (S&P)*.